

A LLM Evaluation Prompt Sample - 1 (without instructions) for Clause A 8.11

[SYSTEM]

Act as an ISMS Lead auditor. Assess whether the cybersecurity policy document defines controls in alignment with ISO/IEC 27002:2022 guidance.

[USER]

CONTROL : A.8.11 Data masking

REQUIREMENT : Data masking: Data masking shall be used in accordance with the organizations topic-specific policy on access control and other related policies, and business requirements, taking applicable legislation into consideration

POLICY EVIDENCE (5 chunks from submitted policy document):

[Chunk 1 | Data Management Policy > Policy] Policy Data Acquisition There are no Implementation group safeguards that support this portion of the data management process. Data Inventory IT must conduct an inventory of data on an annual basis. All sensitive data must be marked accordingly in the data inventory. A data owner must be associated with all data tracked within the inventory. Data with specific data retention needs must be labeled accordingly. All data owners are required to contact IT upon the creation of, or obtaining, sensitive data to ensure the data is tracked within the data inventory. Data Classification IT must establish and enforce labels for sensitive data. IT must review data classification labels and their usage on an annual basis. Data Protection IT must configure access control lists on enterprise assets in accordance with users need to know. This is to include laptops, smartphones, tablets, centralized file systems, remote file systems, databases, and all applications. Sensitive data must be encrypted on all user devices. Data Handling IT must develop and maintain a written data retention plan. All data and documents must be preserved for the appropriate amount of time as dictated by regulatory, legal, and business requirements. Data Disposal IT, or other authorized parties, must destroy data that have outlasted their specified retention timeframes .

[Chunk 2 | Data Management Policy > Responsibility] Data Management Policy Purpose Managing data within an enterprise includes data classification, inventory, handling, retention, and disposal. The Data Management Policy provides the processes and procedures for governing data within the enterprise. This includes creating a data inventory and classifying data based on sensitivity. Additionally, procedures for securely protecting data from unauthorized access or modification alongside appropriate for methods for how users should handle their data during their day-to-day work activities. Finally,

authorized methods to destroy and remove data from the enterprise are discussed.

[Chunk 3 | Acceptable Use Policy > Exceptions] Applicability This policy is meant to apply to all users within the enterprise who receive and utilize enterprise assets, which includes all members of the workforce (both on-site and remote), third-party vendors, contractors, service providers, consultants, or any other individual that operates an enterprise asset. It is the users responsibility to read and understand this policy and to conduct their activities in accordance with its terms. In addition, users must read and understand the enterprises Information Security Policy and its associated standards. Users who find the policy statements within this document to be unclear are encouraged to reach out to IT in order to clarify any remaining ambiguities.

[Chunk 4 | Acceptable Use Policy > Policy] Policy User Responsibilities Users must only use approved technology and services. All enterprise assets are on loan to users so that essential job functions may be performed. Upon separation from the enterprise or contract termination, all supplied IT assets, and the associated data must be returned by the user. Users must secure the physical environment around their workstation and lock their computers when stepping away. Users must ensure that Personally Identifiable Information (PII), confidential, and any sensitive data that may be covered by government or other regulation, is not readily available or accessible on their desks or within their workspace. All users must take appropriate care to protect information, systems and related assets within their custody or care from loss, damage, or harm. Lost or damaged equipment must be reported to IT as soon as practical. Users must store their passwords in a secure manner. Approved password managers must be used to store passwords digitally. Users-assigned accounts must only access assets, operating systems, applications, files, and data to which they have been granted access. The ability to inadvertently read, execute, modify, delete, or copy data does not imply permission to do so.

[Chunk 5 | Security Awareness Training Policy > Policy] Policy Assess There are no IG1 safeguards that support this portion of the security awareness training process. Develop A program for performing security awareness training must be established. This process must be documented and approved. Educate Users must receive security awareness training, at a minimum, on an annual basis. All new users must receive cybersecurity awareness training before being granted access to enterprise assets. Users must be trained on how to recognize social engineering attacks. Users must be trained on best practices for authentication in the enterprise. Users must be trained on best practices for handling enterprise data. Training must be included on the following subjects as it pertains to the enterprises Data Management Policy: Identifying sensitive data Storing sensitive data Transferring sensitive data Archiving sensitive data Destroying sensitive data Any legal and / or regulatory obligations of the above . Clear screen and clean desk best practices must be included in the

training. Timeframes for automatic session locking for enterprise assets are contained within the Secure Configuration Management Policy. Users must be trained on the causes of unintentional data exposure in the enterprise. Users must be trained on how to recognize and report security incidents. Users must be trained on how to identify and report if their enterprise assets are missing security updates.

Evaluate the CONTROL above. Output ONLY the JSON object:

A.1 Output of Granite4.1:8b

```
{
  "control": "A.8.11 Data masking",
  "requirement": "Data masking: Data masking shall be used in accordance
    with the organizations topic-specific policy on access control and
    other related policies, and business requirements, taking applicable
    legislation into consideration",
  "alignment": {
    "aligned": false,
    "evidence": [
      {
        "chunk": 1,
        "relevant_section": "Data Protection IT must configure access
          control lists on enterprise assets in accordance with users need to
          know. This is to include laptops, smartphones, tablets, centralized
          file systems, remote file systems, databases, and all applications.
          Sensitive data must be encrypted on all user devices.",
        "notes": "This chunk discusses encryption of sensitive data but
          does not specifically mention data masking techniques."
      },
      {
        "chunk": 2,
        "relevant_section": "Data Management Policy Purpose Managing data
          within an enterprise includes data classification, inventory,
          handling, retention, and disposal. The Data Management Policy
          provides the processes and procedures for governing data within the
          enterprise.",
        "notes": "This chunk outlines the scope of the policy but lacks
          specific reference to data masking."
      },
      {
        "chunk": 3,
        "relevant_section": "Applicability This policy is meant to apply
          to all users within the enterprise who receive and utilize enterprise
          assets, which includes all members of the workforce (both on-site
          and remote), third-party vendors, contractors, service providers,
```

```

consultants, or any other individual that operates an enterprise
asset.",
  "notes": "This chunk addresses user responsibilities broadly but
does not detail data masking."
},
{
  "chunk": 4,
  "relevant_section": "Users must ensure that Personally
Identifiable Information (PII), confidential, and any sensitive data
that may be covered by government or other regulation, is not readily
available or accessible on their desks or within their workspace.",
  "notes": "This chunk emphasizes physical security of sensitive
data but does not mention masking techniques."
},
{
  "chunk": 5,
  "relevant_section": "Training must be included on the following
subjects as it pertains to the enterprises Data Management Policy:
Identifying sensitive data Storing sensitive data Transferring
sensitive data Archiving sensitive data Destroying sensitive data Any
legal and / or regulatory obligations of the above.",
  "notes": "This chunk covers training topics related to data
management but does not explicitly address data masking."
}
],
"gap_analysis": {
  "identified_gap": "The policy document lacks explicit mention of
data masking techniques as required by ISO/IEC 27002:2022 for control
A.8.11.",
  "recommendation": "Add a specific clause in the Data Management
Policy that mandates the use of data masking techniques where
appropriate, aligned with access control policies and legal
requirements."
}
}
}

```

A.2 Output of Granite 4.1:3b

```

{ "assessment": "partial_compliance", "reasoning": "The policy document
includes provisions related to data protection, such as encrypting
sensitive data on user devices (Data Protection section) and
establishing access control lists on enterprise assets (Data Handling
section). However, it does not explicitly define a specific control
for data masking in alignment with ISO/IEC 27002:2022 guidance. The
policy mentions general responsibilities related to handling
sensitive data (Acceptable Use Policy > Policy), but there is no
dedicated control or procedure outlined for implementing data masking
as per Control A.8.11 requirement." }

```

A.3 Output of Granite 3.3:8b

```
{ "Control_Alignment": { "ISO_IEC_27002_2022_Version": "2022", "
Control_ID": "A.8.11", "Control_Name": "Data masking", "
Policy_Evidence_Assessment": [ { "Chunk_Number": 1, "Policy_Section":
"Data Management Policy > Data Classification", "Relevance": "High",
"Satisfied": true, "Comments": "The policy establishes data
classification and labels for sensitive data, which aligns with the
requirement for data masking." }, { "Chunk_Number": 1, "
Policy_Section": "Data Management Policy > Data Protection", "
Relevance": "High", "Satisfied": true, "Comments": "Access control
lists are configured on enterprise assets in accordance with users'
need-to-know, which supports data masking." }, { "Chunk_Number": 2, "
Policy_Section": "Data Management Policy > Purpose", "Relevance": "
High", "Satisfied": true, "Comments": "The policy covers managing
data within the enterprise, including securely protecting data from
unauthorized access or modification." }, { "Chunk_Number": 3, "
Policy_Section": "Acceptable Use Policy > Exceptions", "Relevance": "
Medium", "Satisfied": false, "Comments": "The Acceptable Use Policy
does not explicitly mention data masking. It focuses on general user
responsibilities and access to enterprise assets." }, { "Chunk_Number
": 4, "Policy_Section": "Acceptable Use Policy > Policy", "Relevance
": "Medium", "Satisfied": false, "Comments": "The Acceptable Use
Policy does not specifically address data masking. It focuses on
general user responsibilities related to enterprise assets." }, { "
Chunk_Number": 5, "Policy_Section": "Security Awareness Training
Policy > Policy", "Relevance": "Low", "Satisfied": false, "Comments":
"The Security Awareness Training Policy does not explicitly mention
data masking. It focuses on general cybersecurity awareness training
." } ], "Overall_Assessment": "Partial alignment with ISO/IEC
27002:2022 Control A.8.11 - Data masking. While some policies cover
aspects that support data masking, there is no explicit policy
addressing data masking itself.", "Recommendations": [ "Develop a
specific data masking policy or update existing policies to
explicitly address data masking requirements in line with ISO/IEC
27002:2022 Control A.8.11." ] } }
```

A.4 Output of llama3.2:3b

```
{"control": "A.8.11", "requirement": "Data masking: Data masking shall be
used in accordance with the organizations topic-specific policy on
access control and other related policies, and business requirements,
taking applicable legislation into consideration", "policy_evidence
": {"chunks": "[Chunk 1, Chunk 2, Chunk 3, Chunk 4, Chunk 5]"} }
```

A.5 Output of mistral:7b

```
{ "Control": "A.8.11 - Data masking", "Alignment with ISO/IEC 27002:2022
  guidance": { "Data Masking": { "Evidence": [ // Chunk 1: Data
    Inventory, Data Classification, Data Protection, Data Handling, Data
    Disposal (from Data Management Policy) "IT must configure access
    control lists on enterprise assets in accordance with users need to
    know. This is to include laptops, smartphones, tablets, centralized
    file systems, remote file systems, databases, and all applications.",
    "Sensitive data must be encrypted on all user devices.", "Data
    Protection IT must develop and maintain a written data retention plan
    .", // Chunk 4: User Responsibilities (from Acceptable Use Policy) "
    Users must ensure that Personally Identifiable Information (PII),
    confidential, and any sensitive data that may be covered by
    government or other regulation, is not readily available or
    accessible on their desks or within their workspace.", // Chunk 5:
    Security Awareness Training Policy (Policy) "Users must be trained on
    how to recognize social engineering attacks.", "Users must be
    trained on best practices for handling enterprise data." ], "
    Conclusion": "The policy document provides evidence that aligns with
    the ISO/IEC 27002:2022 guidance for Data Masking, as it addresses
    aspects such as data protection, data encryption, and user training
    on handling sensitive data." } } }
```

A.6 Output of gemma3:4b

```
{
  "control_id": "A.8.11",
  "control_name": "Data masking",
  "requirement": "Data masking: Data masking shall be used in accordance
    with the organizations topic-specific policy on access control and
    other related policies, and business requirements, taking applicable
    legislation into consideration",
  "assessment": "PARTIALLY MET",
  "justification": "The policy document demonstrates some elements
    related to data masking, but lacks a clearly defined and implemented
    data masking strategy. Chunks 1-4 discuss data classification,
    inventory, access control, and encryption all of which are
    foundational to data masking. However, there is no explicit mention
    of a data masking process itself, nor any details on how masking is
    applied to sensitive data. The policy references access control lists
    and encryption, which are related to data protection, but don't
    directly address the specific requirement of data masking. The
    Acceptable Use Policy (Chunk 3) emphasizes user responsibility for
    handling sensitive data, which is a necessary component of a data
    masking strategy. The Security Awareness Training Policy (Chunk 5)
    includes training on identifying and handling sensitive data, further
    supporting the need for data masking. However, the policy lacks
```

```

specific procedures or technical controls related to data masking,
making it difficult to determine if the requirement is fully met.
Further investigation is needed to understand the actual
implementation of data masking controls within the organization.",
"recommendations": [
  "Develop and document a specific data masking policy that outlines
  the types of data subject to masking, the masking techniques to be
  used, and the roles and responsibilities involved.",
  "Implement technical controls to support data masking, such as data
  masking software or database-level masking.",
  "Update the Security Awareness Training Policy (Chunk 5) to include
  specific training on data masking procedures and techniques.",
  "Conduct a gap analysis to identify any missing controls or processes
  related to data masking."
],
"evidence_reviewed": [
  "Chunk 1",
  "Chunk 2",
  "Chunk 3",
  "Chunk 4",
  "Chunk 5"
]
}

```

A.7 Output of gemma3n:e2b

```

{
  "control_name": "A.8.11 Data masking",
  "policy_definition_assessment": "The provided policy excerpt does not
  explicitly define controls related to data masking. While it mentions
  data masking in the context of the organization's data management
  policy, it lacks specific details on how data masking is implemented,
  its scope, or the technologies used. The policy references the
  organization's topic-specific data access control and other related
  policies, as well as business requirements, but does not elaborate on
  the data masking implementation details. It also mentions
  applicable legislation, but doesn't specify which laws or regulations
  are relevant to data masking. Therefore, the policy does not fully
  align with ISO/IEC 27002:2022 guidance on data masking, which
  requires a documented process for data masking that considers data
  sensitivity, access control, and legal requirements.",
  "iso27002_alignment_assessment": "The policy excerpt does not
  demonstrate alignment with ISO/IEC 27002:2022 requirements for data
  masking. Specifically, it lacks the detailed implementation guidance
  and considerations for data masking that ISO/IEC 27002:2022 expects.
  The reference to 'topic-specific policy' is insufficient without
  further details on the implementation.",
  "key_missing_elements": [

```

```

    "Specific data masking technologies or techniques.",
    "Details on how data masking is applied to different types of data.",
    "Processes for managing data masking exceptions.",
    "Consideration of data masking for specific regulatory requirements
    .",
    "Details on the roles and responsibilities related to data masking."
  ],
  "recommendations": [
    "Expand the data management policy to include a detailed description
    of the data masking process.",
    "Specify the data masking technologies and techniques to be used.",
    "Define the scope of data masking (e.g., which types of data are
    masked, where data is masked).",
    "Document the process for managing data masking exceptions.",
    "Ensure that the data masking process considers applicable legal and
    regulatory requirements.",
    "Assign roles and responsibilities for data masking.",
    "Regularly review and update the data masking process to ensure its
    effectiveness."
  ]
}

```

A.8 Output of phi4:14b

```

{
  "control_evaluation": {
    "control_id": "A.8.11",
    "control_name": "Data masking",
    "requirement_summary": "Data masking shall be used in accordance with
    the organizations topic-specific policy on access control and other
    related policies, and business requirements, taking applicable
    legislation into consideration.",
    "policy_chunks_reviewed": [
      {
        "chunk_id": 1,
        "relevant_content": "Sensitive data must be encrypted on all user
        devices. Data Protection IT must configure access control lists on
        enterprise assets in accordance with users need to know."
      },
      {
        "chunk_id": 2,
        "relevant_content": "Managing data within an enterprise includes
        data classification, inventory, handling, retention, and disposal."
      }
    ],
    "alignment_with_iso_27002_2022": {
      "data_masking_reference": true,

```



```

    "description": "ISO/IEC 27002:2022 emphasizes the importance of
protecting sensitive information through various controls including
encryption and access control. The policy document mentions data
protection measures such as encryption and configuring access control
lists, which align with the principles of data masking by ensuring
that sensitive data is protected in accordance with business
requirements and legislation.",
    "gaps": [
        {
            "issue": "Lack of explicit mention of data masking techniques
or processes",
            "suggestion": "The policy should explicitly define data masking
as a control measure, detailing its application within the
organization's data protection strategy."
        }
    ],
    "conclusion": "While the cybersecurity policy document aligns with
ISO/IEC 27002:2022 guidance on protecting sensitive information
through encryption and access controls, it lacks an explicit
definition or mention of data masking as a control measure. To fully
comply with A.8.11 Data Masking requirements, the organization
should consider incorporating specific references to data masking
techniques and their application within its cybersecurity framework."
}
}

```

B LLM Evaluation Prompt Sample - 2 (with instructions) for Clause A 8.11

[SYSTEM]

Act as an ISMS Lead auditor. Assess whether the cybersecurity policy document defines controls in alignment with ISO/IEC 27002:2022 guidance.

Scope:

- Evaluate ONLY documented policy content
- Do NOT assess implementation or evidence
- Do NOT infer unstated intent

Evaluation Criteria (ALL required for conformity):

- Control objective is clear
- Requirement is mandatory (shall/must)
- Requirement is specific and actionable
- Scope/applicability is defined.
- Responsibility is assigned

STANDARD: ISO 27002:2022 | SECTOR: Financial Services Banking

===

AUDIT RULES (apply strictly in order):

1. If ANY criterion is completely missing NON-CONFORMITY.
2. If ALL are present CONFORMITY.
3. When uncertain NON-CONFORMITY.
4. Confidence scoring:
 - 90-100 : policy is explicit, specific, assigns responsibility, and defines enforcement/review for every obligation
 - 55-89 : mostly covered but missing some specifics, responsibility gaps, or incomplete enforcement definition
 - 30-54 : control topic mentioned but vague, generic, or missing key elements
 - 0-29 : absent or only tangentially referenced

===

Output ONLY a valid JSON object no text, explanation, markdown, or commentary before or after the JSON.

```
{
  "status": "<CONFORMITY or NON-CONFORMITY>",
  "confidence": <integer 0-100>,
  "justification": "<one precise sentence stating the verdict, explicitly
    supported with evidence references including page number, section
```

```

    number, sub-section number, and/or heading from the provided policy
    chunks only>",
    "strengths": "<comma-separated list of key elements that are well-
    defined (ONLY if CONFORMITY, else NONE)>",
    "gaps": "<comma-separated list of missing or under-specified policy
    elements, or NONE>",
    "obligations": [
      {"req": "<obligation name>", "met": "<YES or NO>", "note": "<Chunk N
      policy detail, max 10 words>"}
    ]
  }
}

```

[USER]

CONTROL : A.8.11 Data masking

REQUIREMENT : Data masking: Data masking shall be used in accordance with the organizations topic-specific policy on access control and other related policies, and business requirements, taking applicable legislation into consideration

POLICY EVIDENCE (5 chunks from submitted policy document):

[Chunk 1 | Data Management Policy > Policy] Policy Data Acquisition There are no Implementation group safeguards that support this portion of the data management process. Data Inventory IT must conduct an inventory of data on an annual basis. All sensitive data must be marked accordingly in the data inventory. A data owner must be associated with all data tracked within the inventory. Data with specific data retention needs must be labeled accordingly. All data owners are required to contact IT upon the creation of, or obtaining, sensitive data to ensure the data is tracked within the data inventory. Data Classification IT must establish and enforce labels for sensitive data. IT must review data classification labels and their usage on an annual basis. Data Protection IT must configure access control lists on enterprise assets in accordance with users need to know. This is to include laptops, smartphones, tablets, centralized file systems, remote file systems, databases, and all applications. Sensitive data must be encrypted on all user devices. Data Handling IT must develop and maintain a written data retention plan. All data and documents must be preserved for the appropriate amount of time as dictated by regulatory, legal, and business requirements. Data Disposal IT, or other authorized parties, must destroy data that have outlasted their specified retention timeframes

[Chunk 2 | Data Management Policy > Responsibility] Data Management Policy Purpose Managing data within an enterprise includes data classification, inventory, handling, retention, and disposal. The Data Management Policy provides the processes and procedures for governing data within the enterprise. This includes creating a data inventory and classifying data based on sensitivity. Additionally, procedures for securely protecting data from unauthorized access or modification alongside appropriate for methods for how users should

handle their data during their day-to-day work activities. Finally, authorized methods to destroy and remove data from the enterprise are discussed.

[Chunk 3 | Acceptable Use Policy > Exceptions] Applicability This policy is meant to apply to all users within the enterprise who receive and utilize enterprise assets, which includes all members of the workforce (both on-site and remote), third-party vendors, contractors, service providers, consultants, or any other individual that operates an enterprise asset. It is the users responsibility to read and understand this policy and to conduct their activities in accordance with its terms. In addition, users must read and understand the enterprises Information Security Policy and its associated standards. Users who find the policy statements within this document to be unclear are encouraged to reach out to IT in order to clarify any remaining ambiguities.

[Chunk 4 | Acceptable Use Policy > Policy] Policy User Responsibilities Users must only use approved technology and services. All enterprise assets are on loan to users so that essential job functions may be performed. Upon separation from the enterprise or contract termination, all supplied IT assets, and the associated data must be returned by the user. Users must secure the physical environment around their workstation and lock their computers when stepping away. Users must ensure that Personally Identifiable Information (PII), confidential, and any sensitive data that may be covered by government or other regulation, is not readily available or accessible on their desks or within their workspace. All users must take appropriate care to protect information, systems and related assets within their custody or care from loss, damage, or harm. Lost or damaged equipment must be reported to IT as soon as practical. Users must store their passwords in a secure manner. Approved password managers must be used to store passwords digitally. Users-assigned accounts must only access assets, operating systems, applications, files, and data to which they have been granted access. The ability to inadvertently read, execute, modify, delete, or copy data does not imply permission to do so.

[Chunk 5 | Security Awareness Training Policy > Policy] Policy Assess There are no IG1 safeguards that support this portion of the security awareness training process. Develop A program for performing security awareness training must be established. This process must be documented and approved. Educate Users must receive security awareness training, at a minimum, on an annual basis. All new users must receive cybersecurity awareness training before being granted access to enterprise assets. Users must be trained on how to recognize social engineering attacks. Users must be trained on best practices for authentication in the enterprise. Users must be trained on best practices for handling enterprise data. Training must be included on the following subjects as it pertains to the enterprises Data Management Policy: Identifying sensitive data Storing sensitive data Transferring sensitive data Archiving sensitive data Destroying sensitive data Any legal and / or regulatory obligations of the above

. Clear screen and clean desk best practices must be included in the training. Timeframes for automatic session locking for enterprise assets are contained within the Secure Configuration Management Policy. Users must be trained on the causes of unintentional data exposure in the enterprise. Users must be trained on how to recognize and report security incidents. Users must be trained on how to identify and report if their enterprise assets are missing security updates.

Evaluate the CONTROL above. Output ONLY the JSON object:

B.1 Output of Granite4.1:8b

```
{ "status": "NON-CONFORMITY", "confidence": 30, "justification": "Data
masking requirement is mentioned but lacks mandatory language,
specific actions, and defined responsibility.", "strengths": "NONE",
"gaps": "Mandatory clause missing, no specific actionable steps,
responsibility not assigned, scope/applicability undefined.", "
obligations": [ { "req": "Data masking shall be used in accordance
with the organizations topic-specific policy on access control and
other related policies, and business requirements, taking applicable
legislation into consideration", "met": "NO", "note": "Chunk 1 Data
Protection mentions encryption but not masking" } ] }
```

B.2 Output of Granite 4.1:3b

```
{ "status": "NON-CONFORMITY", "confidence": 30, "justification": "The
policy evidence does not contain any specific mention or definition
of data masking controls, including responsibilities assigned for
implementing data masking in accordance with ISO/IEC 27002:2022
guidance.", "strengths": "", "gaps": "Data masking control objective,
requirement specifics, scope/applicability, and responsibility
assignments are all missing from the provided policy chunks." }
```

B.3 Output of Granite 3.3:8b

```
{ "status": "NON-CONFORMITY", "confidence": 30, "justification": "The
policy does not explicitly mention data masking as a requirement.", "
strengths": "NONE", "gaps": "Data masking is absent or only
tangentially referenced in the provided policy chunks.", "obligations
": [ {"req": "Data masking: Data masking shall be used in accordance
with the organizations topic-specific policy on access control and
other related policies, and business requirements, taking applicable
legislation into consideration", "met": "NO", "note": "[Chunk 1, 2,
3, 4, 5 No explicit mention of data masking]"} ] }
```

B.4 Output of llama3.2:3b

```
{ "status": "NON-CONFORMITY", "confidence": 30, "justification": "The
  control objective is not clear, as 'Data masking shall be used in
  accordance with the organizations topic-specific policy on access
  control and other related policies, and business requirements' does
  not specify what data masking entails or how it should be implemented
  .", "strengths": "", "gaps": "Control objective clarity, specific
  implementation details, and responsibility assignment", "obligations
  ": [ {"req": "Data masking", "met": "NO", "note": "Chunk 1 Data
  Management Policy > Policy"} ] }
```

B.5 Output of mistral:7b

```
{ "status": "CONFORMITY", "confidence": 90, "justification": "Control
  objective is clear, requirement is mandatory, requirement is specific
  and actionable, scope/applicability is defined (Data masking in
  accordance with the organizations topic-specific policy on access
  control and other related policies), responsibility is assigned (data
  owners must contact IT upon creation of sensitive data)", "strengths
  ": ["control objective", "mandatory requirement", "specific and
  actionable", "defined scope/applicability", "assigned responsibility
  "], "gaps": "NONE", "obligations": [ {"req": "Data masking", "met": "
  YES", "note": "Chunk 1 Data Inventory"} ] }
```

B.6 Output of gemma3:4b

```
{
  "status": "NON-CONFORMITY",
  "confidence": 65,
  "justification": "While the policy references data masking and
  encryption, it lacks a specific requirement to use data masking in
  accordance with a defined policy and business requirements, and
  doesnt detail the types of masking techniques or the scope of data
  subject to masking, referencing only access control and other related
  policies which is insufficiently specific, relying on broader
  policies instead of a dedicated data masking strategy (Chunk 1).",
  "strengths": "References data encryption and data classification,
  indicating an awareness of related security controls.",
  "gaps": "Missing specific requirements for data masking implementation,
  scope, and associated policies; no mention of masking techniques or
  enforcement mechanisms.",
  "obligations": [
    {"req": "Data masking shall be used in accordance with the
    organizations topic-specific policy on access control and other
    related policies, and business requirements, taking applicable
    legislation into consideration", "met": "NO", "note": "Reference to
    broader policies lacks specificity and actionable detail."},
```

```

    {"req": "Data masking", "met": "NO", "note": "No specific
requirements or procedures outlined."},
    {"req": "Business requirements", "met": "NO", "note": "No connection
to business requirements established."},
    {"req": "Applicable legislation", "met": "NO", "note": "No mention of
specific legislation considered."}
  ]
}

```

B.7 Output of gemma3n:e2b

```

{
  "status": "NON-CONFORMITY",
  "confidence": 30,
  "justification": "The policy statement lacks a mandatory requirement, a
specific and actionable requirement, and a defined scope/
applicability for data masking. It mentions data masking but does not
specify the mandatory nature, how to implement it, or who is
responsible for it.",
  "strengths": "Data Management Policy > Policy, Data Classification, Data
Protection, Data Disposal",
  "gaps": "Data masking shall be used in accordance with the organizations
topic-specific policy on access control and other related policies,
and business requirements, taking applicable legislation into
consideration",
  "obligations": [
    {"req": "Data masking", "met": "NO", "note": "Data Management Policy >
Policy - Data masking: Data masking shall be used in accordaance
with the organizations topic-specic policy on access control and
other related policies, and business requirements, taking applicable
legislation into consideration"}
  ]
}

```

B.8 Output of phi4:14b

```

{
  "status": "NON-CONFORMITY",
  "confidence": 30,
  "justification": "The control objective is vague, lacking specificity
in actionable requirements and defined scope/applicability (Chunk 1)
.",
  "strengths": "NONE",
  "gaps": "Control objective clarity, requirement specificity, scope/
applicability definition, responsibility assignment",
}

```

```
"obligations": [  
  {"req": "Clear control objective", "met": "NO", "note": "Chunk 1  
Vague data management process"},  
  {"req": "Mandatory and specific requirement", "met": "NO", "note": "  
Chunk 1 General reference to policies"},  
  {"req": "Defined scope/applicability", "met": "NO", "note": "Chunk 1  
No explicit scope for data masking"},  
  {"req": "Assigned responsibility", "met": "NO", "note": "Chunk 1 No  
specific assignment"}  
]  
}
```


C LLM Evaluation Prompt Sample - 3 (Without instructions) for Clause A 5.11

[SYSTEM]

Act as an ISMS Lead auditor. Assess whether the cybersecurity policy document defines controls in alignment with ISO/IEC 27002:2022 guidance.

[USER]

CONTROL : A.5.11 - Return of assets

REQUIREMENT : Personnel and other interested parties as appropriate shall return all the organization's assets in their possession upon change or termination of their employment, contract or agreement.

POLICY EVIDENCE (5 chunks from submitted policy document):

[Chunk 1 | p.81 | 1 Asset Owner > 4.6 Lost, Stolen, or Damaged IT Assets] through the my-oorganization Incident Management process. 4.5.4 Employee Offboarding All departing faculty members, staff, researchers, and contractual personnel shall return my-oorganization-owned IT assets to the designated authority on or before their last working day. Human Resources (HR), in coordination with the IT Services team, shall ensure that all issued assets are identified, collected, and formally returned for reassignment or further processing. If assets are not returned by the last working day, the individual shall be required to immediately return or securely ship the assets to the Institute. Failure to do so may result in recovery of replacement costs and, where applicable, further administrative or legal action in accordance with my-oorganization regulations. In cases of internal transfer between departments or centres within my-oorganization, assigned IT assets shall remain with the original department unless formally reassigned through the IT Services team. 4.6 Lost, Stolen, or Damaged IT Assets my-oorganization does not provide insurance coverage for loss, theft, or damage of IT assets. Users are responsible for the reasonable care, secure handling, and authorised use of all Institute-owned IT assets assigned to them. Any incident that compromises the confidentiality, integrity, or availability of an IT asset shall be

[Chunk 2 | p.82 | 1 Asset Owner > 4.7 Asset Return, Disposal, and Sanitisation] 4. Upon verification and approval, the IT Services team shall arrange for a replacement asset based on availability and institutional approval. 5. Replacement assets may differ in configuration or specifications depending on inventory availability and asset lifecycle standards. 6. Costs arising from negligence, misuse, unauthorised modifications, or repeated incidents may be recovered from the responsible individual or department in accordance with my-oorganization policies. 4.7 Asset Return, Disposal, and Sanitisation All IT assets that are surplus, replaced, damaged beyond repair, or have reached the end of their useful life shall be returned to the my-oorganization IT Services team for reassignment,

secure recycling, or disposal. Employees, students, or staff members shall not retain computing devices replaced under refresh or replacement programmes. Asset return requests shall be initiated through the Institutes approved Helpdesk or Services Portal. Prior to disposal, recycling, or repurposing, all data stored on IT assets shall be securely sanitised. The sanitisation method shall be selected based on data sensitivity and asset type and may include low-level formatting, cryptographic erasure, or recognised industry-standard wiping methods. Media containing confidential, sensitive, or personally identifiable information (PII) that is not being

[Chunk 3 | p.77 | 1 Asset Owner] , disposed, lost, or stolen assets are promptly updated in the asset inventory. Ensuring that shared devices are allocated to the appropriate school or department when not assigned to a specific individual. Ensuring staff return all assigned IT assets upon transfer or end of employment. 2 AssetCustodian/ Using assigned IT assets responsibly and ensuring they are not End User used by unauthorised third parties. Maintaining the physical security and proper care of assigned devices whether on campus, off campus, in use, or stored. Immediately reporting loss, theft, or damage of IT assets to the IT Service Desk. Ensuring that devices left on campus overnight are stored securely in a locked location. Not installing unauthorised or unlicensed software; software requests must follow approved institutional processes. Coordinating all repairs through the IT Service Desk; unauthorised repairs are prohibited and may void warranties. Returning IT assets to the IT Service Desk for reallocation rather than transferring them informally to another individual. Informing the IT Service Desk before transferring to another department to ensure asset inventory accuracy. Ensuring laptop taken home are safeguarded and available during emergencies or unexpected Institute closures.

[Chunk 4 | p.8182 | 1 Asset Owner > 4.6 Lost, Stolen, or Damaged IT Assets] of IT assets. Users are responsible for the reasonable care, secure handling, and authorised use of all Institute-owned IT assets assigned to them. Any incident that compromises the confidentiality, integrity, or availability of an IT asset shall be reported without delay through the Institutes defined reporting channels. 4.6.1 Reporting and Replacement Procedure 1. Loss, theft, or suspected theft of an IT asset shall be reported immediately to the Institute Security Office or the nearest police station. In such cases, a First Information Report (FIR) shall be filed and a copy submitted to the IT Services team for official records and further action. 2. A formal incident report shall be submitted detailing the asset type, asset identification number, last known location, and a brief description of the incident. 3. Damaged IT assets shall be returned to the IT Services team for inspection, assessment, and documentation. Failure to return a damaged asset may result in the incident being treated as a loss. 4. Upon verification and approval, the IT Services team shall arrange for a replacement asset based on availability and institutional approval. 5. Replacement assets may

differ in configuration or specifications depending on inventory availability and asset lifecycle standards.

[Chunk 5 | p.7677 | 1 Asset Owner] logical location. (f) Assigned user, role, or department. 4. All inventoried assets shall either remain under the custody of the IT Services unit or be formally assigned to a faculty member, staff member, researcher, or department. 5. Loss, theft, or suspected compromise of any asset shall be reported immediately to the IT Service Desk and Institute Security, as applicable. 6. Any discrepancies in asset location, ownership, or usage shall be promptly reported and corrected in the asset inventory.

4.2 Responsibilities of Asset Owners and Asset Custodians The asset owners and asset custodians shall be responsible for managing information and IT assets as outlined in the table below. Table 3.1: Roles and Responsibilities for IT Asset Management

#	Role	Key Responsibilities
1	Asset Owner	Ensuring that all IT assets under their department are recorded in the central IT asset inventory. Classifying information and ensuring that asset records are reviewed and updated periodically. Ensuring that newly purchased, transferred, disposed, lost, or stolen assets are promptly updated in the asset inventory. Ensuring that shared devices are allocated to the appropriate school or department when not assigned to a specific individual. Ensuring staff return all assigned IT assets upon transfer or end

Evaluate the CONTROL above. Output ONLY the JSON object:

C.1 Output of Granite 4.1:8b

```
{
  "control": "A.5.11 Return of assets",
  "requirement": "Personnel and other interested parties as appropriate shall return all the organizations assets in their possession upon change or termination of their employment, contract or agreement.",
  "policy_evidence": [
    {
      "chunk_id": "Chunk 1",
      "page": 81,
      "content": "All departing faculty members, staff, researchers, and contractual personnel shall return my-oorganization-owned IT assets to the designated authority on or before their last working day. Human Resources (HR), in coordination with the IT Services team, shall ensure that all issued assets are identified, collected, and formally returned for reassignment or further processing."
    },
    {
      "chunk_id": "Chunk 2",
      "page": 82,
      "content": "All IT assets that are surplus, replaced, damaged beyond repair, or have reached the end of their useful life shall be
```

```

    returned to the my-oorganization IT Services team for reassignment,
    secure recycling, or disposal."
  },
  {
    "chunk_id": "Chunk 3",
    "page": 77,
    "content": "Ensuring that staff return all assigned IT assets upon
transfer or end of employment."
  },
  {
    "chunk_id": "Chunk 4",
    "pages": [81, 82],
    "content": "Loss, theft, or suspected theft of an IT asset shall be
reported immediately to the Institute Security Office or the nearest
police station. A formal incident report shall be submitted
detailing the asset type, asset identification number, last known
location, and a brief description of the incident."
  },
  {
    "chunk_id": "Chunk 5",
    "pages": [76, 77],
    "content": "Ensuring staff return all assigned IT assets upon
transfer or end of employment. Loss, theft, or suspected compromise
of any asset shall be reported immediately to the IT Service Desk and
Institute Security."
  }
],
"alignment_with_ISO_27002_2022": {
  "status": "Aligned",
  "explanation": "The policy document clearly defines procedures for
the return of assets upon termination of employment, contract, or
agreement, including responsibilities of HR, IT Services, and asset
owners. It addresses reporting mechanisms for lost, stolen, or
damaged assets and ensures secure handling and disposal in line with
ISO/IEC 27002:2022 guidance on asset management (Clause A.5.11)."
},
"non_conformities": [],
"recommendations": []
}

```

C.2 Output of Granite 4.1:3b

```

{ "assessment": "The cybersecurity policy document defines the control A
.5.11 Return of assets in alignment with ISO/IEC 27002:2022 guidance
. The policy clearly states that personnel and other interested
parties shall return all organizations assets upon change or
termination of employment, contract, or agreement. It includes
detailed procedures for handling asset returns during offboarding

```

```
processes, ensuring proper identification, collection, and formal
return to designated authorities. Additionally, it addresses
consequences for non-compliance, such as recovery of replacement
costs and potential legal actions. The policy also covers reporting
mechanisms for loss, theft, or damage of IT assets, aligning with ISO
/IEC 27002 requirements for incident management and asset lifecycle
management." }
```

C.3 Output of Granite 3.3:8b

```
{ "Control_ID": "A.5.11", "Control_Name": "Return of assets", "
  ISO_IEC_27002_Version": "2022", "Control_Objective": "Personnel and
  other interested parties as appropriate shall return all the
  organizations assets in their possession upon change or termination
  of their employment, contract or agreement.", "
  Policy_Alignment_Assessment": { "Aligned_Sections": [ "4.5.4 Employee
  Offboarding", "4.6 Lost, Stolen, or Damaged IT Assets", "4.7 Asset
  Return, Disposal, and Sanitisation" ], "Partial_Alignment_Notes": [ "
  The policy covers the return of assets upon termination, change, or
  internal transfer, aligning with the control objective.", "It
  specifies responsibilities for HR and IT Services teams in
  coordinating asset returns, which supports the requirement.", "The
  policy also addresses secure disposal and sanitization of assets,
  covering end-of-life processes." ], "Unaligned_Aspects": [ "The
  policy does not explicitly mention consequences for failure to return
  assets within a specified timeframe (e.g., 'on or before their last
  working day'), although it implies potential recovery costs and
  administrative/legal action.", "While the policy covers asset
  disposal and sanitization, it doesn't specifically address the return
  of assets by interested parties other than personnel, such as
  contractors or third-party entities." ], "Recommendations": [ "
  Clearly define timelines for returning assets to ensure alignment
  with the 'upon change or termination' requirement.", "Extend asset
  return policies to cover interested parties beyond employees and
  explicitly include contractual agreements." ] } }
```

C.4 Output of llama3.2:3b

```
{"control": "A.5.11", "requirement": "Personnel and other interested
  parties as appropriate shall return all the organization\u2019s
  assets in their possession upon change or termination of their
  employment, contract or agreement.", "policy_evidence": {"chunk": 1,
  "page": 81, "text": "...through the my-oorganization Incident
  Management process. ..."} }
```

C.5 Output of mistral:7b

```
{ "Control": "A.5.11 - Return of assets", "Alignment with ISO/IEC
  27002:2022 guidance": true, "Reasoning": "The policy document
  provides clear requirements for personnel and other interested
  parties to return organization's assets upon change or termination of
  their employment, contract or agreement (A.5.11.1). It also outlines
  procedures for handling lost, stolen, damaged, or surplus IT assets
  (A.4.6, A.4.7), ensuring secure sanitization of data before disposal
  or recycling (A.4.7.3), and reporting incidents involving IT assets (
  A.4.6.1). The document also defines responsibilities of asset owners
  and custodians (A.4.2) which aligns with the ISO/IEC 27002:2022
  guidance." }
```

C.6 Output of gemma3:4b

```
{
  "control_id": "A.5.11",
  "control_name": "Return of assets",
  "requirement": "Personnel and other interested parties as appropriate
    shall return all the organizations assets in their possession upon
    change or termination of their employment, contract or agreement.",
  "assessment": {
    "alignment_with_iso_iec_27002": "Partially Aligned",
    "justification": "The policy document demonstrates a reasonable
      effort to address the requirement of returning assets upon change or
      termination. However, it lacks specific detail regarding the process
      for verifying asset return, particularly concerning offboarding
      procedures. While it mandates return by HR and IT Services, the
      policy doesn't explicitly outline the steps taken to ensure complete
      asset retrieval (e.g., confirmation of return, secure disposal of
      data, revocation of access rights). The reliance on the Incident
      Management process (4.6) for lost/stolen assets is somewhat indirect.
      ISO/IEC 27002:2022 emphasizes a robust process for managing asset
      lifecycle, including secure disposal and data sanitization, which is
      only partially addressed here. The policy's focus on replacement
      assets and potential recovery costs is relevant but doesn't fully
      align with the core principle of complete asset return.",
    "strengths": [
      "Mandates return of assets upon change or termination.",
      "Identifies key stakeholders (HR, IT Services).",
      "Includes procedures for damaged assets and reporting loss/theft."
    ],
    "weaknesses": [
      "Lacks detailed offboarding procedures.",
      "Insufficient emphasis on data sanitization and secure disposal.",
      "Reliance on the Incident Management process is not a clearly
      defined control."
    ]
  }
}
```

```

    "No specific verification mechanism for asset return."
  ],
  "recommendations": [
    "Develop a formal offboarding checklist and process for verifying asset return.",
    "Implement a documented data sanitization procedure aligned with ISO/IEC 27002:2022 standards.",
    "Clearly define roles and responsibilities for asset return verification.",
    "Integrate asset return into the broader asset lifecycle management process."
  ]
}
}

```

C.7 Output of gemma3n:e2b

```

{
  "control_name": "A.5.11 Return of assets",
  "alignment_with_iso27002": "Yes",
  "assessment": "The control aligns with ISO/IEC 27002:2022 guidance. It addresses the requirement for personnel and other interested parties to return organizational assets upon change or termination. This is a fundamental principle for maintaining asset integrity, preventing loss, and ensuring proper disposal. The policy provides a clear process for asset return, including responsibilities, reporting procedures, and consequences for non-compliance. The reference to the 'my-oo-rganizaion Incident Management process' and the 'Asset Inventory' further strengthens its alignment with ISO 27002 principles of asset management and incident response.",
  "key_iso27002_references": [
    "A.5.11",
    "A.5.4",
    "A.6",
    "A.7",
    "A.6.1",
    "A.2"
  ],
  "notes": "The policy demonstrates a comprehensive approach to asset return, covering responsibilities, reporting, and consequences. The inclusion of data sanitization procedures is also a positive aspect, aligning with the need to protect sensitive information."
}

```

C.8 Output of phi4:14b

```

{
  "control_evaluation": {
    "control_id": "A.5.11",
    "requirement_summary": "Personnel and other interested parties shall
return all organizations assets in their possession upon change or
termination of employment, contract, or agreement.",
    "policy_alignment": true,
    "evaluation_details": {
      "asset_return_policy": {
        "description": "The policy mandates that departing faculty
members, staff, researchers, and contractual personnel must return my
-organization-owned IT assets to the designated authority on or
before their last working day. HR coordinates with IT Services for
asset identification, collection, and formal return.",
        "compliance_with_iso_27002": true,
        "specifics": [
          {
            "procedure": "Departing individuals are required to return or
securely ship unreturned assets immediately after the last working
day.",
            "consequences": "Failure may result in recovery of
replacement costs and further administrative or legal action."
          },
          {
            "internal_transfer_policy": "IT assets remain with the
original department unless reassigned through IT Services, ensuring
proper asset management during internal transfers."
          }
        ]
      },
      "asset_sanitisation_and_disposal": {
        "description": "All surplus, replaced, damaged beyond repair, or
end-of-life IT assets must be returned for reassignment, recycling,
or disposal. Data sanitization is required before disposal.",
        "compliance_with_iso_27002": true,
        "specifics": [
          {
            "sanitisation_methods": "Includes low-level formatting,
cryptographic erasure, or recognized industry-standard wiping methods
based on data sensitivity and asset type."
          }
        ]
      },
      "incident_reporting_and_management": {
        "description": "Users must report any incidents compromising IT
assets' confidentiality, integrity, or availability immediately. Loss
, theft, or damage reporting procedures are clearly defined.",
        "compliance_with_iso_27002": true,
        "specifics": [

```



```

    {
      "reporting_procedure": "Immediate reporting to the Institute
Security Office or nearest police station for loss or theft, with a
formal incident report submitted."
    }
  ],
  "asset_custodianship_and_responsibility": {
    "description": "Asset owners and custodians are responsible for
managing IT assets, ensuring accurate inventory records, and
reporting any discrepancies.",
    "compliance_with_iso_27002": true,
    "specifics": [
      {
        "inventory_management": "All inventoried assets must be under
the custody of IT Services or formally assigned to a specific
individual or department."
      }
    ]
  },
  "conclusion": "The cybersecurity policy document aligns with ISO/IEC
27002:2022 guidance for control A.5.11, defining comprehensive
procedures for asset return, sanitization, incident reporting, and
custodianship responsibilities."
}

```

D LLM Evaluation Prompt Sample - 4 (With instructions) for Clause A 5.11

[SYSTEM]

Act as an ISMS Lead auditor. Assess whether the cybersecurity policy document defines controls in alignment with ISO/IEC 27002:2022 guidance.

Scope:

- Evaluate ONLY documented policy content
- Do NOT assess implementation or evidence
- Do NOT infer unstated intent

Evaluation Criteria (ALL required for conformity):

- Control objective is clear
- Requirement is mandatory (shall/must)
- Requirement is specific and actionable
- Scope/applicability is defined.
- Responsibility is assigned

STANDARD: ISO 27002:2022 | SECTOR: Education Higher Education

===

AUDIT RULES (apply strictly in order):

1. If ANY criterion is completely missing NON-CONFORMITY.
2. If ALL are present CONFORMITY.
3. When uncertain NON-CONFORMITY.
4. Confidence scoring:
 - 90-100 : policy is explicit, specific, assigns responsibility, and defines enforcement/review for every obligation
 - 55-89 : mostly covered but missing some specifics, responsibility gaps, or incomplete enforcement definition
 - 30-54 : control topic mentioned but vague, generic, or missing key elements
 - 0-29 : absent or only tangentially referenced

===

Output ONLY a valid JSON object no text, explanation, markdown, or commentary before or after the JSON.

```
{
  "status": "<CONFORMITY or NON-CONFORMITY>",
  "confidence": <integer 0-100>,
  "justification": "<one precise sentence stating the verdict, explicitly supported with evidence references including page number, section"
```

```

    number, sub-section number, and/or heading from the provided policy
    chunks only>",
    "strengths": "<comma-separated list of key elements that are well-
    defined (ONLY if CONFORMITY, else NONE)>",
    "gaps": "<comma-separated list of missing or under-specified policy
    elements, or NONE>",
    "obligations": [
      {"req": "<obligation name>", "met": "<YES or NO>", "note": "<Chunk N
      policy detail, max 10 words>"}
    ]
  }
}

```

[USER]

CONTROL : A.5.11 Return of assets

REQUIREMENT : Personnel and other interested parties as appropriate shall return all the organizations assets in their possession upon change or termination of their employment, contract or agreement.

POLICY EVIDENCE (5 chunks from submitted policy document):

[Chunk 1 | p.81 | 1 Asset Owner > 4.6 Lost, Stolen, or Damaged IT Assets] through the my-oorganization Incident Management process. 4.5.4 Employee Offboarding All departing faculty members, staff, researchers, and contractual personnel shall return my-oorganization-owned IT assets to the designated authority on or before their last working day. Human Resources (HR), in coordination with the IT Services team, shall ensure that all issued assets are identified, collected, and formally returned for reassignment or further processing. If assets are not returned by the last working day, the individual shall be required to immediately return or securely ship the assets to the Institute. Failure to do so may result in recovery of replacement costs and, where applicable, further administrative or legal action in accordance with my-oorganization regulations. In cases of internal transfer between departments or centres within my-oorganization, assigned IT assets shall remain with the original department unless formally reassigned through the IT Services team. 4.6 Lost, Stolen, or Damaged IT Assets my-oorganization does not provide insurance coverage for loss, theft, or damage of IT assets. Users are responsible for the reasonable care, secure handling, and authorised use of all Institute-owned IT assets assigned to them. Any incident that compromises the confidentiality, integrity, or availability of an IT asset shall be

[Chunk 2 | p.82 | 1 Asset Owner > 4.7 Asset Return, Disposal, and Sanitisation] 4. Upon verification and approval, the IT Services team shall arrange for a replacement asset based on availability and institutional approval. 5. Replacement assets may differ in configuration or specifications depending on inventory availability and asset lifecycle standards. 6. Costs arising from negligence, misuse, unauthorised modifications, or repeated incidents may be recovered from the responsible individual or department in accordance with my-oorganization policies. 4.7 Asset Return, Disposal, and

Sanitisation All IT assets that are surplus, replaced, damaged beyond repair, or have reached the end of their useful life shall be returned to the my-oorganization IT Services team for reassignment, secure recycling, or disposal. Employees, students, or staff members shall not retain computing devices replaced under refresh or replacement programmes. Asset return requests shall be initiated through the Institutes approved Helpdesk or Services Portal. Prior to disposal, recycling, or repurposing, all data stored on IT assets shall be securely sanitised. The sanitisation method shall be selected based on data sensitivity and asset type and may include low-level formatting, cryptographic erasure, or recognised industry-standard wiping methods. Media containing confidential, sensitive, or personally identifiable information (PII) that is not being

[Chunk 3 | p.77 | 1 Asset Owner] , disposed, lost, or stolen assets are promptly updated in the asset inventory. Ensuring that shared devices are allocated to the appropriate school or department when not assigned to a specific individual. Ensuring staff return all assigned IT assets upon transfer or end of employment. 2 AssetCustodian/ Using assigned IT assets responsibly and ensuring they are not End User used by unauthorised third parties. Maintaining the physical security and proper care of assigned de- vices whether on campus, off campus, in use, or stored. Immediately reporting loss, theft, or damage of IT assets to the IT Service Desk. Ensuringthatdevicesleftoncampusovernightarestoredsecurely in a locked location. Not installing unauthorised or unlicensed software; software re- quests must follow approved institutional processes. Coordinating all repairs through the IT Service Desk; unautho- rised repairs are prohibited and may void warranties. Returning IT assets to the IT Service Desk for reallocation rather than transferring them informally to another individual. Informing the IT Service Desk before transferring to another de- partment to ensure asset inventory accuracy. Ensuringlaptopstakenhomearesafeguardedandavailableduring emergencies or unexpected Institute closures.

[Chunk 4 | p.8182 | 1 Asset Owner > 4.6 Lost, Stolen, or Damaged IT Assets] of IT assets. Users are respon- sible for the reasonable care , secure handling, and authorised use of all Institute-owned IT assets assigned to them. Any incident that compromises the confidentiality, integrity, or availability of an IT asset shall be reported without delay through the Institutes defined reporting channels. 4.6.1 Reporting and Replacement Procedure 1. Loss, theft, or suspected theft of an IT asset shall be reported immediately to the Institute Security Office or the nearest police station. In such cases, a First Information Report (FIR) shall be filed and a copy submitted to the IT Services team for official records and further action. 2. A formal incident report shall be submitted detailing the asset type, asset identification number, last known location, and a brief description of the incident. 3. Damaged IT assets shall be returned to the IT Services team for inspection, assessment, and documentation. Failure to return a damaged asset may result in the incident being treated as a loss. 4. Upon verification and approval,

the IT Services team shall arrange for a replacement asset based on availability and institutional approval. 5. Replacement assets may differ in configuration or specifications depending on inventory availability and asset lifecycle standards.

[Chunk 5 | p.7677 | 1 Asset Owner] logical location. (f) Assigned user, role, or department. 4. All inventoried assets shall either remain under the custody of the IT Services unit or be formally assigned to a faculty member, staff member, researcher, or department. 5. Loss, theft, or suspected compromise of any asset shall be reported immediately to the IT Service Desk and Institute Security, as applicable. 6. Any discrepancies in asset location, ownership, or usage shall be promptly reported and corrected in the asset inventory. 4.2 Responsibilities of Asset Owners and Asset Custodians The asset owners and asset custodians shall be responsible for managing information and IT assets as outlined in the table below. Table 3.1: Roles and Responsibilities for IT Asset Management # Role Key Responsibilities 1 Asset Owner Ensuring that all IT assets under their department are recorded in the central IT asset inventory. Classifying information and ensuring that asset records are reviewed and updated periodically. Ensuring that newly purchased, transferred, disposed, lost, or stolen assets are promptly updated in the asset inventory. Ensuring that shared devices are allocated to the appropriate school or department when not assigned to a specific individual. Ensuring staff return all assigned IT assets upon transfer or end

Evaluate the CONTROL above. Output ONLY the JSON object:

D.1 Output of Granite 4.1:8b

```
{ "status": "CONFORMITY", "confidence": 95, "justification": "Policy explicitly states mandatory return of organizations assets per ISO/IEC 27002:2022 A.5.11, includes specific actions, responsible parties (HR & IT Services), and consequences for non-compliance; defined in Chunk 14.", "strengths": "Clear control objective, mandatory language ('shall'), specific actionable steps, defined scope/applicability, assigned responsibility.", "gaps": "NONE", "obligations": [ { "req": "Return of assets", "met": "YES", "note": "Chunk 1 Personnel must return all organizations assets upon employment change" } ] }
```

D.2 Output of Granite 4.1:3b

```
{ "status": "CONFORMITY", "confidence": 95, "justification": "The policy clearly states that departing faculty members, staff, researchers, and contractual personnel must return all Institute-owned IT assets to the designated authority on or before their last working day. This
```

```
aligns with ISO/IEC 27002:2022 requirement A.5.11 which mandates
specific responsibility for returning assets upon change or
termination of employment.", "strengths": "Clear definition of who is
responsible, explicit deadline (last working day), and process for
asset return through designated authority and IT Services team.", "
gaps": "", "obligations": [ {"req": "Return of assets", "met": "YES",
"note": "Chunk 2 | p.82 | 4.5.4 Employee Offboarding"} ] }
```

D.3 Output of Granite 3.3:8b

```
{ "status": "CONFORMITY", "confidence": 90, "justification": "The policy
explicitly covers return of assets upon change or termination (p.81,
4.5.4 and p.77, 2), assigns responsibility to HR and IT Services (p
.81, 4.5.4 and p.77, 2), and outlines consequences for non-compliance
(p.81).", "strengths": "Clear objective, mandatory requirement,
specific actions, defined scope, assigned responsibility.", "gaps": "
None", "obligations": [ {"req": "Return of assets upon change or
termination", "met": "YES", "note": "Chunk 1, p.81, 4.5.4 and Chunk
76-77, 2"}, {"req": "Responsibility assignment", "met": "YES", "note
": "Chunk 1, p.81, HR coordination with IT Services; Chunk 77, Asset
Owners and Custodians responsibilities"} ] }
```

D.4 Output of llama3.2:3b

```
{ "status": "CONFORMITY", "confidence": 90, "justification": "The control
objective is clear, and the requirement is mandatory (shall). The
scope/applicability is defined, and responsibility is assigned.", "
strengths": "Clear control objective, specific requirement, well-
defined scope, and responsible party identified.", "gaps": "", "
obligations": [ {"req": "Return of assets", "met": "YES", "note": "
Chunk 4 4.6 Lost, Stolen, or Damaged IT Assets"} ] }
```

D.5 Output of mistral:7b

```
{ "status": "CONFORMITY", "confidence": 90, "justification": "Requirement
is mandatory ('shall'), specific and actionable, scope/applicability
is defined, and responsibility is assigned.", "strengths": ["
Requirement", "Scope/applicability"], "gaps": "None", "obligations":
[ {"req": "Return of assets", "met": "YES", "note": "Chunk 4 4.5.4
Employee Offboarding"} ] }
```

D.6 Output of gemma3:4b

```
{
  "status": "NON-CONFORMITY",
  "confidence": 65,
  "justification": "While the policy outlines requirements for returning assets upon termination and reporting loss/theft, it lacks specific actionable steps and clear responsibility assignments beyond stating HR and IT Services collaborate. Specifically, Chunk 4 details reporting channels but doesn't mandate immediate reporting, and Chunk 5 mentions updating the inventory but doesn't define the frequency or process. The requirement to return all the organizations assets is too broad and lacks detail regarding the process for secure handling and sanitization, which is crucial for ISO 27002 compliance.",
  "strengths": "None",
  "gaps": "Lack of specific timeframe for asset return, absence of detailed reporting procedures, missing definition of asset sanitization methods, no clear enforcement or review mechanisms, and vague responsibility assignments beyond collaboration.",
  "obligations": [
    {"req": "Personnel and other interested parties as appropriate shall return all the organizations assets in their possession upon change or termination of their employment, contract or agreement.", "met": "NO", "note": "Chunk 2 Policy evidence lacks specific timeframe and process details."},
    {"req": "Human Resources (HR), in coordination with the IT Services team, shall ensure that all issued assets are identified, collected, and formally returned for reassignment or further processing.", "met": "NO", "note": "Chunk 4 Collaboration is stated but lacks detail on the process."},
    {"req": "If assets are not returned by the last working day, the individual shall be required to immediately return or securely ship the assets to the Institute.", "met": "NO", "note": "Chunk 4 Lacks specific consequences and enforcement."},
    {"req": "Failure to do so may result in recovery of replacement costs and, where applicable, further administrative or legal action in accordance with my-oorganization regulations.", "met": "NO", "note": "Chunk 4 Vague consequence and lacks regulatory reference."},
    {"req": "Employees, students, or staff members shall not retain computing devices replaced under refresh or replacement programmes.", "met": "NO", "note": "Chunk 2 Lacks detail on the return process."}
  ]
}
```

D.7 Output of gemma:e2b

```
{
  "status": "NON-CONFORMITY",
```

```

"confidence": 30,
"justification": "The policy states personnel must return assets upon
  change or termination of employment, but it lacks a mandatory
  requirement, specific actionability, and a defined scope/
  applicability. It also lacks a clear assignment of responsibility.",
"strengths": "None",
"gaps": "Mandatory requirement, specific actionability, defined scope/
  applicability, clear assignment of responsibility",
"obligations": [
  {"req": "Return of assets upon change or termination of employment", "
    met": "NO", "note": "Chunk 1 - 4.5.4, Chunk 4 - 4.6.1, Chunk 5 -
    4.2"},
  {"req": "Return of assets on or before last working day", "met": "NO",
    "note": "Chunk 1 - 4.5.4"},
  {"req": "Report loss, theft, or suspected theft of IT assets", "met":
    "NO", "note": "Chunk 1 - 4.6.1"},
  {"req": "Arrange for replacement asset", "met": "NO", "note": "Chunk 4
    - 4.6.1"},
  {"req": "Securely sanitize data on IT assets", "met": "NO", "note": "
    Chunk 2 - 4.7"},
  {"req": "Update asset inventory promptly", "met": "NO", "note": "Chunk
    1 - 4.6.1, Chunk 5 - 4.2"}
]
}

```

D.8 Output of phi4:14b

```

{
  "status": "CONFORMITY",
  "confidence": 90,
  "justification": "The policy explicitly defines control objectives,
    mandates requirements with 'shall', specifies actions, assigns
    responsibility to HR and IT Services, and outlines enforcement (Chunk
    1 p.81).",
  "strengths": "Control objective is clear, requirement is mandatory,
    requirement is specific and actionable, scope/applicability is
    defined, responsibility is assigned.",
  "gaps": "NONE",
  "obligations": [
    {"req": "Clear control objective", "met": "YES", "note": "Chunk 1
      Return of assets upon employment change"},
    {"req": "Mandatory requirement", "met": "YES", "note": "Chunk 1 '
      shall return' is mandatory"},
    {"req": "Specific and actionable requirement", "met": "YES", "note":
      "Chunk 1 Specific actions for asset return"},
    {"req": "Defined scope/applicability", "met": "YES", "note": "Chunk 1
      Applies to personnel changes"},
    {"req": "Assigned responsibility", "met": "YES", "note": "Chunk 1 HR
      and IT Services responsible"}
  ]
}

```


54 Authors Suppressed Due to Excessive Length

}]